

SECURE MCP GOVERNANCE PLATFORM

AI AND MCP ACCESS GOVERNANCE

Portfolio Publication

Governance-first orchestration
for AI tools, MCP servers,
approvals, and audit evidence



Markus Walker

WORKING GOVERNANCE PoC

AI and MCP Access Governance Platform

Structured intake · Risk classification · Human review · Audit evidence

Markus Walker

Security, AI and Cloud Engineer · Brisbane, Australia
markus@markuswalker.com · linkedin.com/in/markus-walker-au

AI and MCP Access Governance Platform



A working security engineering proof of concept that addresses a real and emerging governance gap: organisations lack a repeatable intake, classification, review and audit process for AI agent integrations and MCP-connected tools.

This project demonstrates a complete governance control loop — from structured intake through automated risk classification, human-reviewed approval, and durable audit evidence — implemented as a runnable n8n workflow.

THE PROBLEM

- Sensitive data flows through channels that have never been security-reviewed
- No accountable owner is documented for AI workflows
- No evidence of review exists if an incident occurs
- Security teams cannot demonstrate that controls operated over time

PLATFORM STACK

Platform	Role
n8n Cloud	Workflow orchestration, validation, risk classification, decision routing, evidence
Asana	Human review task queue, remediation tracking, operational audit evidence
Notion	Governance knowledge base, MCP server inventory, control notes, decision records
GitHub	Source control, documentation, workflow exports, JSON schemas

02 / GOVERNANCE FLOW

How the control loop works



Governance control flow — intake through evidence record

Step	Action	Detail
1	Submit	Developer submits via structured Asana intake form
2	Validate	n8n validates required fields, data classification and MCP tool details
3	Classify	Risk signals checked: data class, environment, privilege scope, vendor maturity
4	Route	Low risk: auto-allowed with evidence. Medium/High: named security reviewer
5	Review	Reviewer decides: Approve, Approve with Conditions, or Deny
6	Evidence	Every terminal decision produces a structured JSON audit record

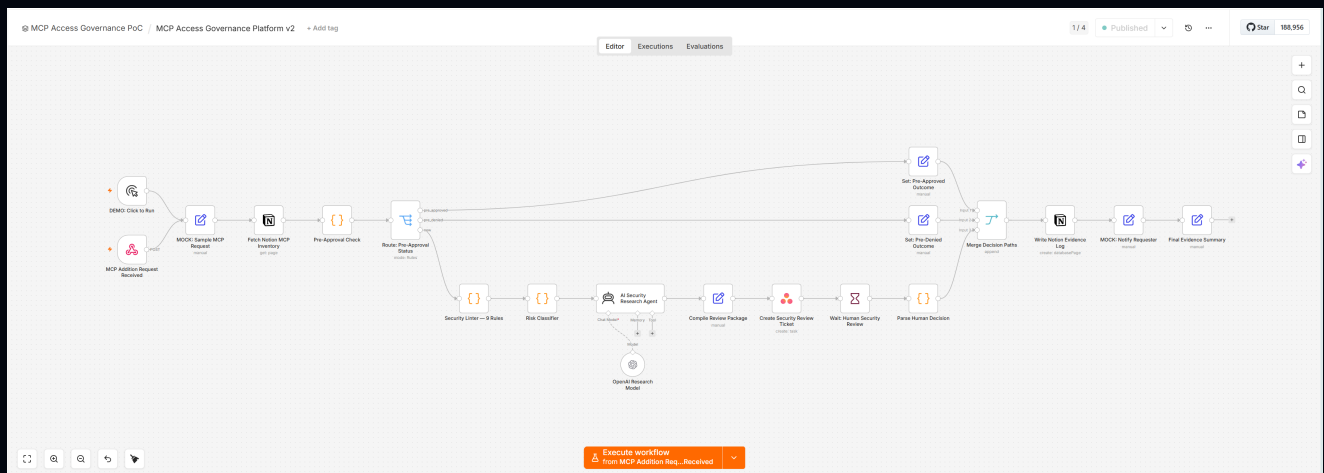
RISK CLASSIFICATION LEVELS

Level	Routing	Outcome
Low	Automated	Auto-allowed with structured evidence record
Medium	Human review	Named reviewer in Asana, structured decision record
High	Human review	Named reviewer, escalation path, conditional approval or deny
Prohibited	Auto-denied	Immediate denial with evidence record, no exception path

03 / WORKFLOW EVIDENCE

n8n workflow — live and runnable

The following screenshot shows the complete n8n workflow as deployed. Every node corresponds directly to a governance control objective. The workflow JSON export is available for direct import into any n8n Cloud or self-hosted n8n instance.



Live n8n workflow export · *intake → validate → classify → route → human review → evidence record*

Property	Value
Workflow name	MCP Access Governance Platform v2
Trigger	Asana new task event (structured intake form)
Key nodes	Webhook receiver, Validate intake, Risk classifier, Route by level, Asana reviewer task, Evidence writer
Evidence output	Structured JSON record per terminal decision
Export format	n8n workflow JSON — importable directly into n8n Cloud or self-hosted

04 / GOVERNANCE CONTROLS

Eight control objectives

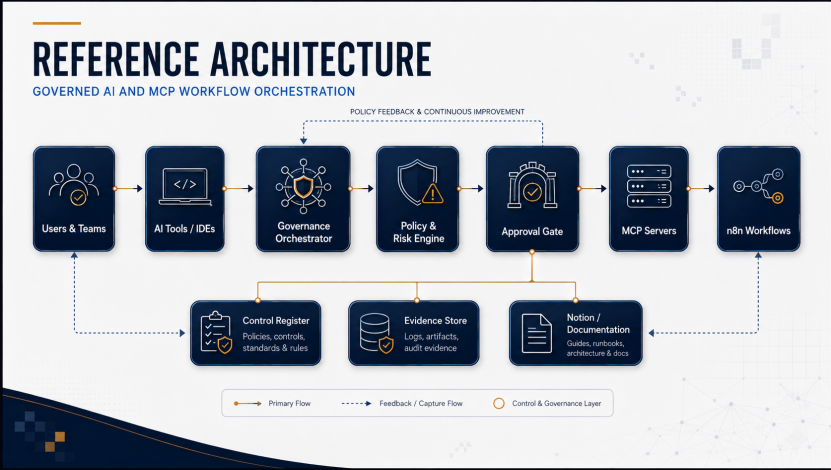


Governance control pillars — identity, least privilege, human approval, audit evidence

Ref	Control Objective
GOV-01	Structured intake — every request captured with required fields
GOV-02	Risk-based decisioning — classification uses documented, consistent criteria
GOV-03	Human accountability — material risk routed to named security reviewer
GOV-04	Audit evidence — every terminal decision produces a structured record
GOV-05	Least privilege — approved access is time-bound and purpose-bound
GOV-06	Safe automation boundary — no provisioning without explicit approval
GOV-07	Scope guardrails — workflow changes follow documented architecture
GOV-08	Periodic review — approved access re-reviewed on material scope change

05 / REFERENCE ARCHITECTURE

Platform architecture



Reference architecture — n8n orchestration with Asana, Notion and GitHub integrations

SECURITY LINTER

A deterministic Python security linter inspects n8n workflow JSON exports for governance risk signals. 42 pytest tests pass across positive, negative, serialisation and integration scenarios. Framework mapping tags embedded in every finding at generation time. Pure functions — deterministic, stateless, side-effect-free.

Rule	Severity	Signal
LINT-001	High	MCP client tool node detected
LINT-002	High	MCP node with credential references
LINT-003	Medium	HTTP node calling MCP-like endpoint directly
LINT-004	High	AI agent node with no human approval gate upstream
LINT-005	Medium	Workflow missing owner metadata
LINT-006	Low	Workflow missing risk classification metadata

Standards and frameworks

Framework	Alignment Area
ISO/IEC 27001	Access control, supplier risk, change management, auditability
ISO/IEC 42001	AI management, human oversight, accountability, lifecycle governance
NIST SP 800-37	Risk management framework structure
NIST SP 800-30	Risk assessment language and treatment
CSA AI Controls Matrix	Cloud AI governance, access control, data governance
MAESTRO	Agentic AI threat modelling, orchestration and tool execution
OWASP LLM Top 10	Prompt injection, data leakage, tool misuse, excessive agency
MCP Security Guidance	Consent, authorisation, confused deputy protections

The project does not claim formal certification or attestation against any of these frameworks.

WHAT THIS DEMONSTRATES

Capability	Evidence
Security engineering applied to an emerging AI governance PoC	Working PoC with runnable n8n workflow
Governance translated to testable, auditable code	42 passing tests, schema-validated output
Framework alignment at engineering level	Tags embedded in every finding, not just in documents
Evidence-oriented design	Audit chain across every decision path
Full governance documentation	Charter, architecture, design, implementation guide, case study
Honest scoping	PoC limitations documented; no overclaiming

Scope and safety boundaries

- All sample data is fictional
- All workflow exports use fictional placeholder values
- No production infrastructure, live credentials or real customer data are present
- The project does not claim to be a production deployment, formal compliance certification or complete enterprise control environment
- Fictional vendors, mock intake data and demo values are used throughout

CONTACT

Field	Detail
Name	Markus Walker
Role	Security, AI and Cloud Engineer
Location	Brisbane, Queensland, Australia
Email	markus@markuswalker.com
LinkedIn	linkedin.com/in/markus-walker-au
GitHub	github.com/markus-doc
Portfolio	markuswalker.com

Source repository, workflow exports, schemas, documentation and evidence samples:
github.com/markus-doc/MCP_Governance_Platform